PLAYBOOK DE RESPUESTA

PB-01 | Fuerza bruta SSH / RDP

Procedimiento estandarizado de triage y contención para PagoClaro C05

Caso C05: PagoClaro Fintech S.A.S.

Implementación de un SOC Nivel 1 | Ética del Hacking / Ciberseguridad Defensiva

Control documental	Versión 1.0 | 21 de octubre de 2026 Responsable documental: Analista SOC N1 del laboratorio. Alcance: procedimientos defensivos en activos autorizados; sin operaciones sobre terceros.
Activo / ámbito	8 estaciones Windows de operaciones, 3 portátiles Windows de gerencia, 5 macOS de desarrollo, 4 Ubuntu Server (bastión, réplica BD, API y respaldos). La prioridad final depende del activo afectado.

01. Objetivo

Detectar ataques de autenticación contra bastión Ubuntu, servicios internos y estaciones Windows sin afectar operaciones de pago.

02. Disparador, fuente y umbral

Wazuh: logs sshd/Windows Security; NGFW si registra intentos. Ventana operativa propuesta: ≥5 fallos en 5 min por IP contra un usuario, o ≥10 fallos/10 min contra varios usuarios.

03. Severidad inicial y promoción

Media; Alta cuando hay éxito posterior, IP interna lateral o bastión/servicio crítico; Crítica si se confirma uso no autorizado de privilegios.

04. Triage: validación paso a paso

1. Correlacionar IP, host y usuario en ventanas de 5, 10 y 30 minutos.
2. Diferenciar IP externa de redes de Operaciones, Gestión y VPN; cotejar lista de pruebas autorizadas.
3. Revisar autenticaciones exitosas posteriores, cambio de usuario y privilegios.
4. Comprobar exposición real de SSH/RDP y horarios operativos autorizados.
5. Consultar reputación de IP pública sin transferir registros sensibles.

05. Contención autorizada a N1

- Bloqueo temporal de IP externa por control autorizado con caducidad, o respuesta activa previamente aprobada.
- Solicitar al administrador TI bloqueo de cuenta no privilegiada en riesgo y verificar resultado.

06. Acciones no autorizadas a N1

- No reiniciar sshd/RDP en bastión ni deshabilitar cuentas privilegiadas.
- No bloquear subredes internas o la VPN sitio a sitio sin autorización.

07. Evidencia mínima preservada

- Evento Windows 4625 / 4624 o logs sshd; IP, usuario, host, intervalo y contador; IDs Wazuh.
- Resultado correlación de inicios exitosos; evidencia de regla de bloqueo y revocación.

08. Escalamiento obligatorio a N2

Acceso exitoso después de fallos, usuario privilegiado, bastión C05-SRV-01 o IP interna; confirmación de exposición crítica.

09. Criterios de cierre técnico

Se justificó prueba o ataque bloqueado, sin éxito ni desplazamiento; documentar acuse y recomendar MFA y VPN.

10. Mejora continua

Revisar falsos positivos por dispositivos de desarrollo macOS y listas de guardia.

11. Registro y trazabilidad

Bitácora del SOC: referencia INC-C05-AAAA-NNN, hora de la alerta (America/Bogota), activo, sensor, rule.id, analista, clasificación, evidencia inmutable, decisiones, autorización y hora de entrega/cierre. No incluir datos financieros sensibles.

12. Responsable, control de versión y fuente

Responsable: analista SOC N1 | Aprobación: responsable SOC | Versión: 1.0 | Revisión: 21/10/2026 | Fuente base: Parcial_SOC_N1_Etica_Hacking, PB-01 (Fase 6) y Anexo F. Los umbrales numéricos de esta adaptación son propuestas operativas, no detecciones que se haya comprobado activar.